

[doc. web n. 10025835]
Provision of April 24, 2024
Register of Provisions
No. 237 of April 24, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, Members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC (General Data Protection Regulation, hereinafter "Regulation");

HAVING REGARD to the Code on the protection of personal data
(legislative decree June 30, 2003, No. 196), as
amended by legislative decree August 10, 2018 No. 101, containing
provisions for the adaptation of the national
legislation to the aforementioned Regulation (hereinafter
"Code");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Regulation of
the Guarantor No. 1/2000;

REPORTING Prof. Ginevra Cerrina Feroni;

PREMISED

1. THE INSTRUCTIONAL ACTIVITY CARRIED OUT

With a complaint dated August 27, 2022, Mr. XX
complained about receiving a promotional email from
the company Rossi Carta S.r.l. Unipersonale
(hereinafter, Rossi Carta or the Company) and the lack of
response to a request to exercise rights made on June 6, 2022. On November 8, 2022, the
complainant added that he had received another seven
unwanted emails.

In response to the Authority's request for information

from the Company, in a certified email dated December 5, 2022, the
Company stated that it had not responded to the
complainant because the communication had mistakenly
ended up in the "spam" folder of the email system. Furthermore, regarding the sending of the
promotional message, it was stated that the
data controller had processed "only the email address
xx. This address had been entered into our
database (...) as pertaining to individuals who
had given their consent for the
processing of their data for marketing purposes."
At the same time, the Company stated that it had

taken steps to acknowledge the request for opposition and to delete the complainant's data.

On December 15, 2022, Mr. XX complained that he had received only a partial response to his request, as no clarifications were provided regarding the origin of the data, but only about their erroneous inclusion in the lists used for marketing.

On December 26, 2022, he supplemented his observations by adding that he had received a new communication from Rossi Carta requesting confirmation of the email address for an alleged request for subscription to the newsletter.

Prompted by a new request for information from the Office, Rossi Carta replied that the email received by Mr. XX was a simple "transitional" email sent by the system following a request for subscription to the newsletter, a request denied by the complainant and thus presumably made by a third party using Mr. XX's data found on the web; since the request was not confirmed, no subscription was completed.

Nevertheless, on May 14, 2023, the complainant stated that he had received 39 emails, all with identical content but resulting from separate sends. In these emails, the complainant was invited to confirm his phone number included

within the email itself.

Once again, the Office forwarded the complainant's supplement to the Company requesting clarifications regarding what was represented, considering that it - according to what was stated about the functioning of the data collection form - should not have had the complainant's phone number.

In the note received on June 8, 2023, the Company, confirming that it did not hold data of Mr. XX, stated that it had conducted further and subsequent checks following the new supplement, learning only at that time that it had suffered access to its website from IP addresses not belonging to those assigned to Rossi Carta and thus presuming that unauthorized external parties may have sent the contested emails in this manner. However, during the period in question, there were no similar sends to other subjects besides Mr. XX. Furthermore, the incident would have caused serious indexing problems for the Company's e-commerce site pages (rossicarta.it), resulting in a loss of ranking in Google search results.

The statements made by the Company, particularly regarding the technical arguments, were also evaluated by the Department of Digital Technologies and Cybersecurity of the Guarantor, which, at the state of the documents, highlighted the inability of the company to independently and promptly

intercept attacks on its systems and the resulting violations – attacks of which the data controller became aware only following the complaint and various discussions with the Authority and only a few months after the event.

2. THE CONTESTATION OF VIOLATIONS

The Office proceeded to contest the violations identified with the initiation of the procedure dated October 5, 2023, prot. No. 136981/23, notified via certified email. Hereby, the motivations are fully referenced.

expressed in the aforementioned act, Rossi Carta has been challenged for the violation of Articles 5, paragraph 1, letter f), 5, paragraph 2, and 24 of the Regulation for failing to ensure adequate protection of personal data from unauthorized processing and access, through appropriate technical measures that ensure the integrity and confidentiality of personal data and to be able to demonstrate such compliance.

Furthermore, it was also deemed that there was a violation of Article 33 of the Regulation, considering that the described event could constitute a personal data breach that, involving risks to the rights and freedoms of individuals, would have necessitated notification to the Authority pursuant to Article 33 of the Regulation, and considering that no notification of a data breach had been received by the Authority, nor was there any documentation indicating that assessments regarding the level of risk of the event had been made to exclude an obligation to notify.

Finally, regarding the sending of unwanted promotional emails and the lack of response to the exercise of rights, considering that the Company had never provided clarifications regarding the origin of the complainant's data, it was deemed that there was a violation of Articles 12, paragraph 3, and 15 of the Regulation as well as Articles 6 and 7 of the Regulation and Article 130 of the Code.

3. THE DEFENSE OF ROSSI CARTA

By certified email dated November 3, 2023, the Company submitted a defensive memorandum in which it first noted that the receipt of the aforementioned "transitional email" by the complainant would indeed confirm that his email address had been deleted as stated; this email, in fact, is sent only to newly entered addresses precisely to request confirmation of the desire to subscribe to the newsletter.

Regarding the 39 emails containing the complainant's telephone number, the Company reiterated that the newsletter subscription form on the website collects, as the only data, the email address and in no case is there the possibility of also entering a telephone number. In this regard, it reiterated that, during the same period, the Company's website had recorded an anomaly that generated a loop in the system directing every product

page to the home page. This event would have resulted in a gradual de-indexing of the site from Google search results. The Company also added that it had not been able, despite the intervention of IT technicians, to identify the author of the tampering, noting only that it stemmed from a script launched from an IP address external to the Company; however, this anomaly would not "...have produced any removal of personal data, nor did it cause emails to be sent to parties other than Mr. XX." The Company finally attached a technical report and the contracts signed with the hosting service provider and the email marketing service, highlighting the technical measures provided to ensure the security of the processed information, also emphasizing that the mentioned providers were deemed reliable also due to the ISO certifications produced.

In particular, the technical report clarifies that "it was also possible to ascertain that an additional module (on the website) to the CMS Prestashop, a module dedicated to redirects (301, 302, 303 URL redirects – SEO) created a loop sending every request to a page dedicated to a product. This loop caused a gradual but very rapid disappearance from Google's SERPs, leading to the company's visibility in the search engine being positioned very far back.

However, it should be noted that there was an additional anomaly in the IT systems of Rossi Carta related to the same IP address mentioned above. In fact, the

Mailing Services Support Center (...) reported that on February 2 and 3 from the same IP address [...], which is based in Northeast Italy, actions on the account were recorded and specifically on those days all email addresses in the mailing list were moved to the blacklist, resulting in the blocking of the service by the system."

Regarding the failure to notify the personal data breach, as required by Article 33 of the Regulation, the Company believed it did not need to do so because the described anomaly of the system would only have effects on the de-indexing of the site and not on the personal data held by the Company, data which does not include any telephone number. Furthermore, no other user subscribed to the newsletter had complained about receiving anomalous emails.

Finally, regarding the lack of information on the origin of the data, the Company added that "from what was subsequently reconstructed, the entry would have occurred due to the erroneous typing of another email address (...) not belonging to the complainant. On this point, however, it is noted that at any time Mr. XX could have canceled the subscription to the newsletter to avoid receiving

any communication."

With the document supplement of January 23, 2024, and the subsequent hearing on January 24, 2024, the Company added that it would not have been able to notice the anomalous sending of 39 emails to the complainant since the anomaly alert system only activates if more than 50 sendings are made.

4. LEGAL ASSESSMENTS

The peculiarity of the described case and the subsequent document supplements, produced by the Company even in the defensive phase, made it necessary to carry out further technical evaluations by the competent Department.

digital technologies and cybersecurity whose outcomes were recorded in the proceedings with a note dated February 12, 2024. It was observed that, despite the event that occurred and the analyses, including technical ones, conducted by the company following the complaint and discussions with the Authority, the website rossicarta.it still appears to be using the CMS Prestashop version 1.7.6(1). This version is completely outdated and subject to numerous vulnerabilities, some of which are of high severity (see <https://www.cvedetails.com/versionsearch.php?page=1&vendor;=Prestashop&product;=&version;=1.7.6>). For example, it can be noted that the sole version 1.7.6.9 of Prestashop is associated with as many as 23 vulnerabilities, 17 of which are of high severity with a Common Vulnerability Scoring System - CVSS score greater than 8 out of 10 (see https://www.cvedetails.com/vulnerability-list/vendor_id-8950/product_id-15797/version_id-1357198/Prestashop-Prestashop-1.7.6.9.html). Among the reported vulnerabilities, CVE-2022-31181 appears particularly relevant, with a CVSS score of 9.8 out of 10 and known for several months at the time of the alleged "anomaly" on the company's website(2), exploiting which, through an SQL injection attack, it would have been possible to inject and execute a script with malicious code on the platform. The high score of the indicated vulnerability is due to the high risk considered in terms of loss of confidentiality, integrity, and availability of the involved data, the ease of the attack, and the possibility of perpetrating the attack without the need for user privileges.

From these further checks, it was confirmed that the Company was using an outdated system for managing the data collected through the website, which is used for e-commerce activities and, therefore, potentially capable of receiving numerous and heterogeneous data (personal, contact, payment data); this system, affected by vulnerabilities known since the beginning of 2022, was still in use at the time of the events and even after discussions with the Authority, despite updates released by the manufacturer being available since July 2022. All of this highlights profiles of violation of the obligation to ensure adequate protection of personal data from unauthorized processing and access, through appropriate technical measures that ensure the integrity and confidentiality of personal data and to be able to demonstrate such compliance.

For these reasons, it is believed that the violation of Articles 5, paragraph 1, letter f), 5, paragraph 2, and 24 of the Regulation is established. Considering that, at the time of the technical checks conducted by the Authority, the platform for managing the website was still not updated, it is necessary, pursuant to Article 58, paragraph 2, letter d), to order Rossi Carta to adopt, with regard to the content management system of the website rossicarta.it, technical measures that, at the state of the art, are considered adequate to the existing risks in the processing of personal data. Furthermore, in light of the unlawfulness and severity of the conduct, it is believed that the conditions for the application of an administrative pecuniary sanction pursuant to Article 58, paragraph 2, letter i) of the Regulation are met.

Regarding the failure to notify a personal data breach, which is the subject of contestation in the aforementioned initiation of proceedings, the following is observed. Based on the statements made, Rossi Carta would have detected unauthorized access to its systems that would have resulted in the

de-indexing of the website and the blacklisting of all email addresses present in the Company's mailing list (see technical report attached to the defense memorandum of November 3, 2023). Therefore, according to Rossi Carta, such anomalies would not have resulted in a breach of the data collected by Rossi Carta itself, even though they occurred concurrently with the receipt - only by the complainant - of 39 emails requesting confirmation of the phone number. Regarding the complainant's data, the Company stated that it had erroneously processed only the email address that would have been deleted after the first request for information from the Authority (see statement of December 5, 2022). Therefore, the subsequent anomalous submissions, of which the origin is still unknown, would not have resulted in access to the complainant's data retained by the Company.

From the technical checks carried out by the Authority, it emerged, as mentioned, that the Company was using an outdated content management system (CMS) for the website that could potentially allow access to numerous personal data; the existing vulnerabilities could also have allowed the same platform of Rossi Carta to be used for carrying out illicit activities such as, for example, sending phishing emails. Such an eventuality could present a high risk to the rights and freedoms of individuals, making notification to the Authority necessary pursuant to Article 33, paragraph 1 of the Regulation. However, the Company was not aware of such risk and limited itself to recording only the de-indexing of the site and the blacklisting of the addresses. Moreover, the available documentation only attests that the Company suffered external attacks and that, during the same period, it was using inadequate technical measures that could potentially lead to events of the type that occurred.

Furthermore, as mentioned, the Company became aware of what happened only following discussions with the Authority, conducting further technical checks after receiving the initiation of proceedings, when the notification of...

****1. Introduction****

Any potential data breach would have been superfluous.

It follows that the failure to notify the Guarantor - as well as the very ability to assess whether it was necessary - was caused by the lack of adequate measures to ensure the security of processing; since this last circumstance has already been the subject of the corrective and sanctioning measures described above, the aspect of the failure to notify can also be considered absorbed within it, allowing for the omission of further interventions.

****2. Promotional Emails and Rights Exercise****

Finally, regarding the sending of unwanted promotional emails and the lack of response to the exercise of rights, it is noted that the Company did not provide clarifications regarding the origin of the complainant's data, limiting itself to stating, initially, that they had been erroneously included in the contact list without indicating the source; only in the defensive phase did the Company hypothesize that the erroneous inclusion of the complainant's email address was due to a typographical error of that address. In any case, the complainant did not receive a response to his request to exercise his rights (allegedly ending up in the spam folder of the email) and did not receive a response during the investigation (after the request for information from the Guarantor) since the Company provided its justifications only after the initiation of the procedure. For these reasons, the request for access to the data cannot be considered satisfied; similarly, as no consent was obtained for the sending of promotional messages and such sending continued even after the objection, this processing appears to have been carried out in the absence of an adequate legal basis.

****3. General Inability to Ensure Data Processing Control****

This conduct can also be attributed to a general inability of the Company to ensure adequate control over operations involving data processing (formation of lists, management of requests to exercise rights), such that the errors cited by the Company as justification for sending promotional messages and the lack of response to the complainant cannot be considered excusable. Therefore, it is believed that the violation of Articles 12, paragraph 3, and 15 of the Regulation, as well as Articles 6 and 7 of the Regulation and Article 130 of the Code, is established, and it is necessary to impose an administrative pecuniary sanction, pursuant to Article 58, paragraph 2, letter i, of the Regulation.

****4. ORDER FOR THE IMPOSITION OF THE ADMINISTRATIVE PECUNIARY SANCTION****

Based on the above, various provisions of the Regulation and the Code related to processing carried out by Rossi Carta are violated, for which it is necessary to apply Article 83, paragraph 3, of the Regulation, according to which, if, in relation to the same processing or related treatments, a data controller violates, with intent or negligence, various provisions of the Regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation, with consequent application of only the sanction provided for in Article 83, paragraph 5, of the Regulation.

For the purposes of quantifying the administrative sanction, the aforementioned Article 83, paragraph 5, in setting the maximum penalty at the sum of 20 million euros or, for companies, at 4% of the annual global turnover of the previous financial year if higher, specifies the methods for quantifying the aforementioned sanction, which must “in any case [be] effective, proportionate and dissuasive” (Article 83, paragraph 1, of the Regulation), identifying, for this purpose, a series of elements, listed in paragraph 2, to be evaluated when quantifying the related amount.

In fulfillment of this provision, hypothesizing, based on the information available in the last balance sheet (registered as of December 31, 2022), the occurrence of the first hypothesis provided for by the aforementioned Article 83, paragraph 5, and thus quantifying the maximum applicable penalty at 20 million euros, the following aggravating circumstances must be considered:

1. The severity and duration of the violations detected. In particular, regarding the sending of unwanted promotional messages and the lack of response to the request to exercise rights, taking into account the justifications provided and the fact that this was an isolated case, a low level of severity of the violation can be considered. However, regarding the use, for over a year, of inadequately updated systems, there is a potential significant detriment to the data of users of the website *rossi carta.it*, even though there is no knowledge of actual attacks exploiting this vulnerability; the very sending of emails to the complainant - who appears to be the only affected party - resulted from an external attack of unknown origin. For this aspect, therefore, a medium level of severity can be assessed (Article 83, paragraph 2, letter a), of the Regulation);

2. The failure to adopt, by the data controller, adequate measures to mitigate harm to the data subjects since the Company, despite attempts made, did not manage to understand the reasons for the events complained of by the complainant, nor did it notice the vulnerabilities affecting its content management platform of the website (Article 83, paragraph 2, letter c), of the Regulation);

3. The degree of responsibility of the data controller, given that the Company adopted an outdated technological platform and therefore entirely inadequate to avoid serious risks for the personal data it collected, also considering that the vulnerabilities had been known for some time and that an update had been available for months (Article 83, par. 2, lett. d), of the Regulation).

As mitigating factors, the following elements are considered:

1. the number of individuals affected by the violations, as this, while potentially capable of causing significant harm to the data of all users present on the website, in practice (and based on what has been established) only resulted in the sending of emails to the complainant (art. 83, par. 2, lett. a) of the Regulation);
2. the absence of intent regarding the sending of promotional emails without consent and the failure to update the systems, which appear to be attributable to the negligence of the Company; indeed, it acted under the belief that it had adopted measures appropriate to the state of the art without being aware of the level of obsolescence of the systems used and the potential risks resulting from their lack of updating (art. 83, par. 2, lett. b) of the Regulation);
3. the absence of previous relevant violations committed by the data controller (art. 83, par. 2, lett. e) of the Regulation);
4. the degree of cooperation in the interaction with the Supervisory Authority (art. 83, par. 2, lett. f) of the Regulation);
5. the fact that the Company, which meets the criteria for a small enterprise, has suffered economic losses as a result of the attack it experienced which - as stated in the note of June 8, 2023 - were

added to the damages resulting from the flood that occurred in Emilia Romagna, where it is based (art. 83, par. 2, lett. k) of the Regulation).

In an overall perspective of necessary balancing between the rights of the data subjects and the freedom of enterprise, the aforementioned criteria must be prudently evaluated, also in order to limit the economic impact of the sanction.

Therefore, it is believed that - based on the overall elements indicated above - an administrative sanction of a payment of 30,000.00 euros (thirty thousand) should be applied to Rossi Carta, which is equal to 0.15% of the maximum administrative fine of 20 million euros. The maximum administrative fine is identified with reference to the provisions of art. 83, par. 5, of the Regulation, considering that 4% of Rossi Carta's turnover, based on the data reported in the latest financial statement, is less than 20 million euros.

It is noted that the conditions of art. 17 of the Regulation of the Guarantor No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor, for the annotation of the violations noted here in the internal register of the Authority, as provided for by art. 57, par. 1, lett. u) of the Regulation.

It is also believed - considering the relevance of the violations - that, pursuant to art. 166, paragraph 7, of the Code, and art. 16, paragraph 1, of the Regulation of the Guarantor No. 1/2019, the publication of the injunction order on the website of the Guarantor should proceed, as an accessory sanction.

ALL OF THE ABOVE HAVING BEEN STATED, THE GUARANTOR

pursuant to art. 57, par. 1, lett. f), of the Regulation, declares the processing described in the terms of the motivation carried out by Rossi Carta S.r.l., based in via P. D'Altri 76 Cesena (FC), VAT No. 00111730404, unlawful; consequently:

- a) pursuant to art. 58, par. 2, lett. d), orders Rossi Carta to adopt, with regard to the content management system of the website rossicarta.it, technical measures that, at the state of the art, are considered adequate to the existing risks in the processing of personal data;
- b) pursuant to art. 157 of the Code, orders Rossi Carta to communicate to the Authority, within thirty days from the notification of this provision, the initiatives undertaken in order to implement the imposed measure; any failure to comply with the provisions of this point may result in the application of the administrative monetary sanction provided for by art. 83, paragraph 5, of the Regulation.

ORDERS

pursuant to art. 58, par. 2, lett. i), of the Regulation, Rossi Carta S.r.l., in the person of its legal representative, to pay the sum of 30,000.00 euros (thirty thousand) as an administrative monetary sanction for the violations indicated in the motivation; it is noted that the offender, pursuant to art. 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

ORDERS

the aforementioned Company, in case of failure to settle the dispute pursuant to art. 166, paragraph 8, of the Code, to pay the sum of 30,000.00 euros (thirty thousand), according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with art. 27 of law No. 689/1981;

DISPOSES

- a) pursuant to art. 166, paragraph 7, of the Code, the full publication of this provision on the website of the Guarantor;
- b) pursuant to art. 17 of the Regulation of the Guarantor No. 1/2019, orders the annotation in the internal register of the Authority, as provided for by art. 57, par. 1, lett. u) of the Regulation, of the violations and the measures adopted.

Pursuant to art. 78 of Regulation (EU) 2016/679, as well as arts. 152 of the Code and 10 of Legislative Decree No. 150 of September 1, 2011, an appeal against this provision may be made to the ordinary judicial authority, by application.

deposited with the ordinary court of the place where the data controller resides, or, alternatively, with the court of the place of residence of the data subject, within thirty days from the date of communication of the provision itself, or sixty days if the applicant resides abroad.

Rome, April 24, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Cerrina Feroni

THE SECRETARY GENERAL

Mattei

NOTES

1) See in this regard what emerges from the analysis of the site rossicarta.it through the following free services for CMS verification <https://whatcms.org/> and <https://sitechecker.pro/what-is-cms>

2) The vulnerability CVE-2022-31181 has been known since early 2022; the release 1.7.8.7 of the Prestashop CMS was released in July 2022.